



Hunting the Ghost in the Shell Case Studies of Insider Risk

Don Mallory

BSides Toronto - Oct 3, 2026

Disclaimer

The thoughts and opinions shared throughout this presentation are mine alone and not those of my past, present, or future employers

No need to take photos
Wait for the **last** QR code



whoami



- 30+ years in IT, mostly in critical infrastructure
- Healthcare security professional
- CISSP, GSEC, GCED, GCIH, and others.

- Parent
- Student
- Educator
- Professional
- Community advocate
- Volunteer
- Speaker
- Hacker
- Artist



Insider Risk vs Insider Threat

Safety Officer != Protection Officer

- Fire safety / protection officer
- Radiation safety / protection officer

Safety Officer = Awareness

Protection Officer = Responsibility and Action

100% of insiders are a risk

What Constitutes an Insider?



The Person

The actual human being who has decided to go rogue or become disgruntled.

This includes employees at all levels, from junior staff to senior executives who may have privileged access to sensitive information.



The Account

User accounts compromised by external threat actors.

By extension, the compromised account becomes the insider threat, operating with legitimate credentials whilst being controlled by malicious external forces.



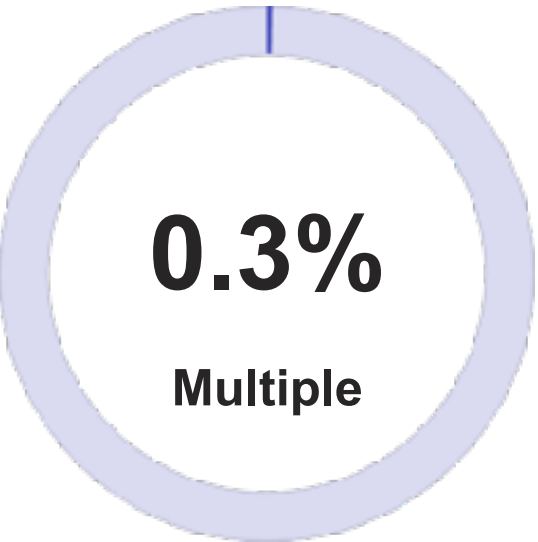
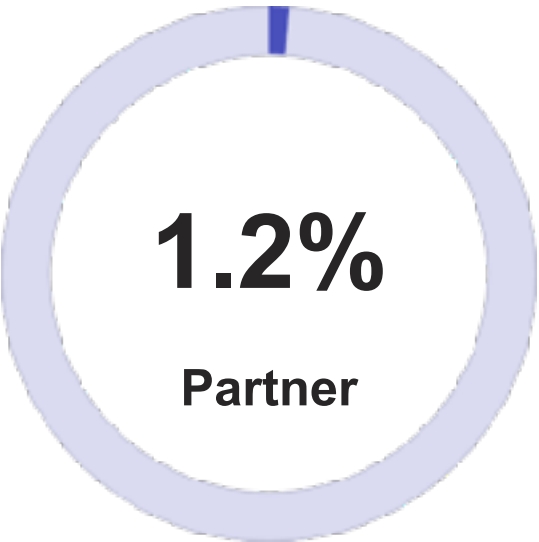
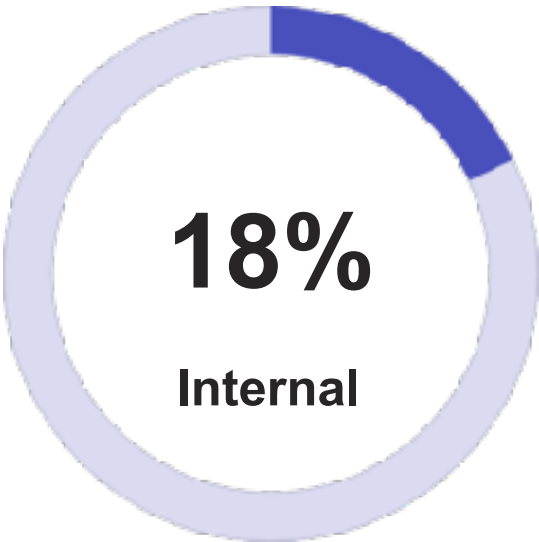
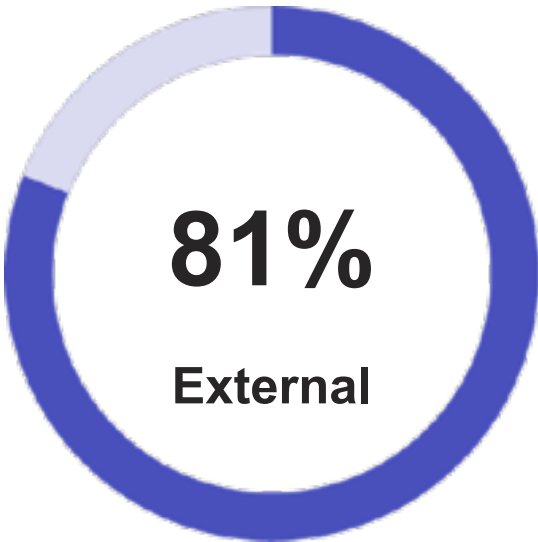
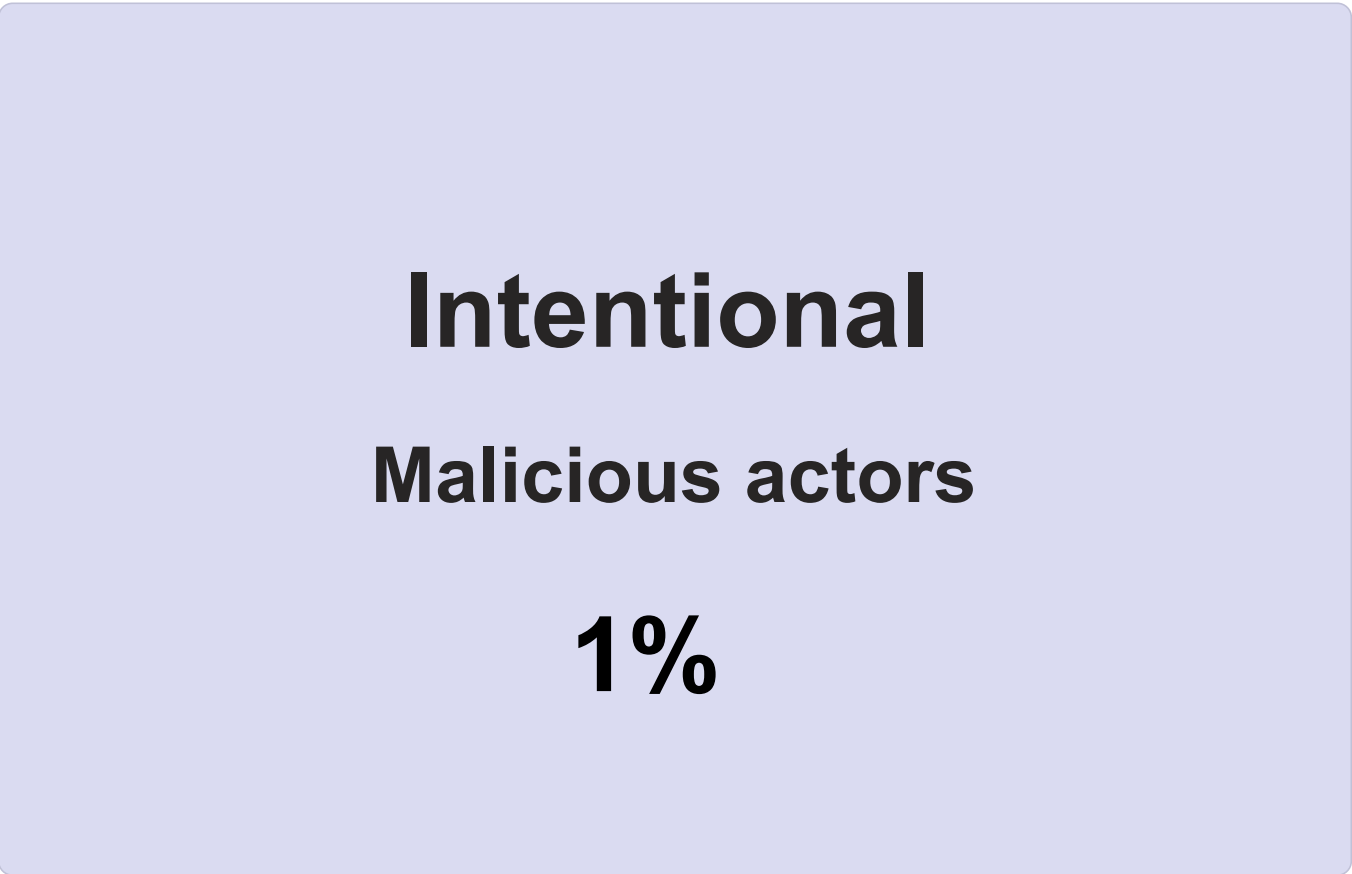
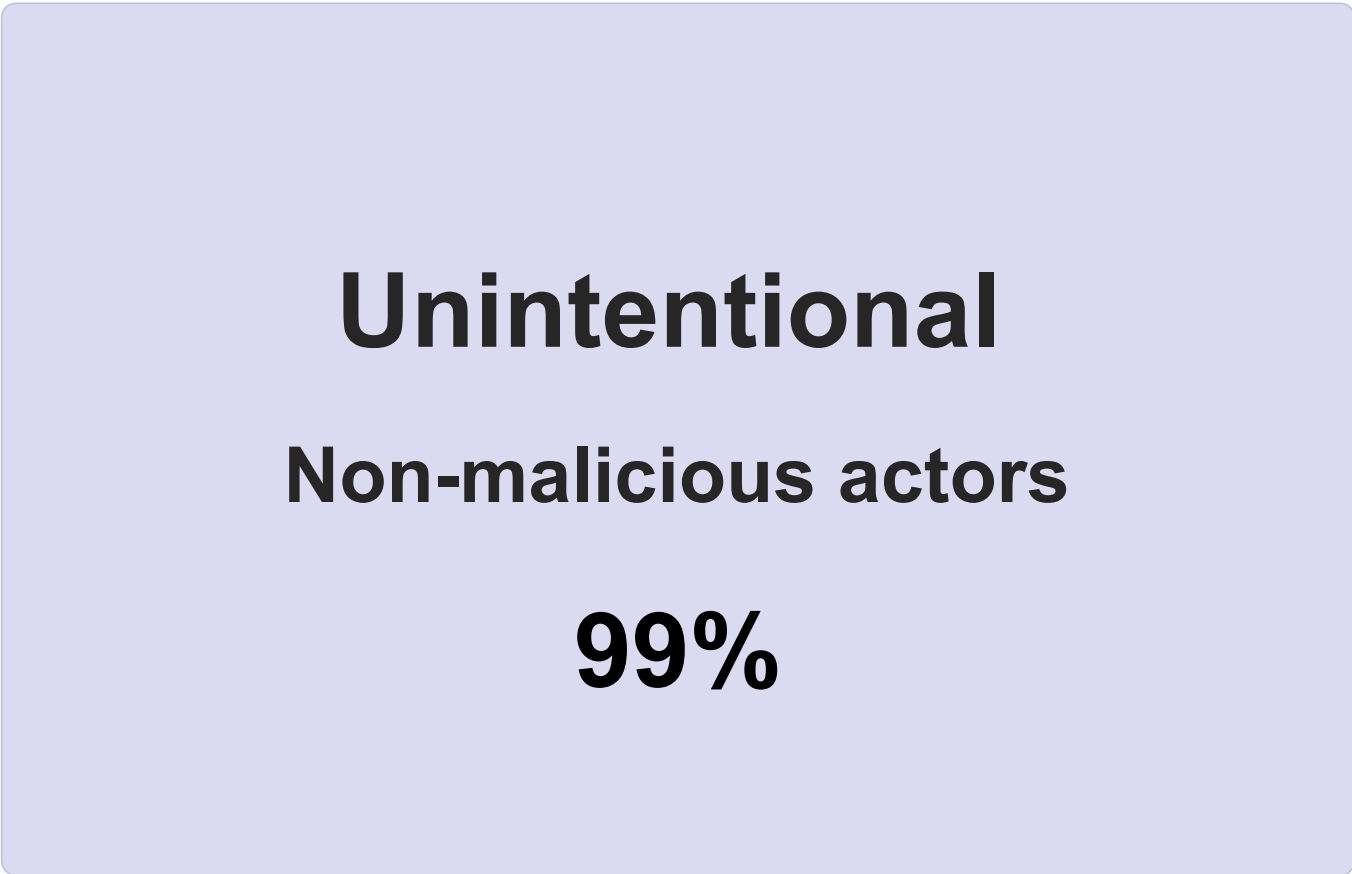
The Device

Hardware such as skimmers on point-of-sale terminals, ATMs, or gas pumps.

This includes supply chain compromises where devices are tampered with before deployment.

Understanding these three vectors is crucial for comprehensive insider risk management. Each requires different detection methods and mitigation strategies, from behavioural analytics for human threats to device integrity monitoring for hardware-based risks.

Types of Insider Threats



Non-malicious / Unintentional

Accidental / Negligent

- Ignored warnings
- Skipped testing
- In a rush

Mistaken

- Push to prod
- Lack of training
- Lack of standards

Outsmarted

- Phished (by outside attackers)

Types of behaviours:

- Higher position (Director and above) increased likelihood to attempt to exfil data
 - "I won't do anything, I just want to use my iPad".
 - I just need to print this out so I can highlight it.
- Communicate AI security and monitoring to employee
- People believe that AI does not violate employee or client privacy
- Employees not trained regarding legal, regulatory, moral obligations
- Unaware of safe methods of sharing information
- Unaware of steps to secure devices
- Sending data to unsecured cloud service
- Circumventing security policies to simplify tasks
- Don't apply updates

49%

Misdelivery

30%

Misconfiguration

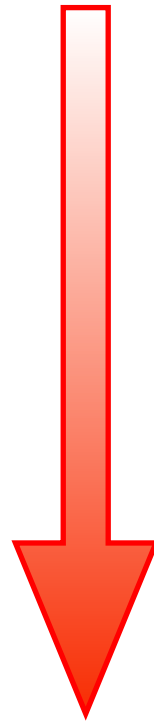
9%

Publishing errors

Malicious / Intentional

- Unauthorized disclosure
- Espionage
- IP theft
- Fraud
- Sabotage
- Workplace violence

Low nefarosity



High nefarosity



Malicious Behaviours

- Email sensitive data to outside parties
- Accessing sensitive data not associated with the role or function
- Downloading or accessing large amounts of data relevant to the role or function
- Scanning for open ports and vulnerabilities
- Unusual or repeated searches
- Data obfuscation or Internet obfuscation methods to conceal activity
- Data preparation, aggregation or conversion into another format
- Coerces other insiders to provide access to information
- Logging in outside of usual hours
- Data hoarding and copying files from sensitive folders
- Accessing data that is outside of an employee's usual behaviour
- Using unauthorized external storage devices like USBs
- Network crawling and searching for sensitive data
- Attempts to disable or bypass existing security controls
- Making multiple requests for access to tools or resources not needed



Typical factors in raising / lowering risk



Personal predispositions

- Narcissism
- Machiavellian manipulativeness
- Psychopathic lack of empath



Emotional Factors

- Anger
- Grievances
- Disgruntlement
- Desire for revenge



Situational stresses

- Workplace grievances



External influences

- Tempting opportunities



Emotional state

- Social environment at work
- Personal relationships



Financial pressures

- Financial pressures or incentives



Organization's culture

Motivations Behind Malicious Insider Threats

Traditional MICE Model

- **Money** - Financial incentives
- **Ideology** - Belief-driven actions
- **Coercion/Compromise** - Forced participation
- **Ego** - Recognition or status

Modern 4 F's Framework

- **Finances** - Economic pressures
- **Fame** - Seeking recognition
- **Fun** - Thrill-seeking behaviour
- **Forced** - Coercion or desperation

Bad boss. Bad team. Bad culture. Cancelled contract / Impactful re-org.

89%

Financial

Money remains the primary driver for malicious insider activity

10%

Espionage

Industrial or state-sponsored information gathering

5%

Grudge

Revenge against employer or colleagues

2.9%

Other

1.9%

Fun

1.9%

Convenience

Common Fallacies About Insider Threats

We aren't a target

We're too small to matter

It could never happen to us

We trust our people

Nobody would ever do that

Hybrid and remote staff are more likely to be threats

People who are bad at their jobs are insider threats



The Financial Impact

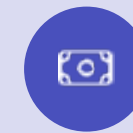
\$4.99M

Average cost of a malicious insider breach



287 Days

Average time to detect and contain malicious insider threats



\$4.28M

Cost of accidental data loss incidents



Detection Challenge

Extremely difficult to distinguish between legitimate and malicious authenticated behaviour

Soft Triggers to Monitor



Employee Status Changes

- New hire
- Resignation
- Role change



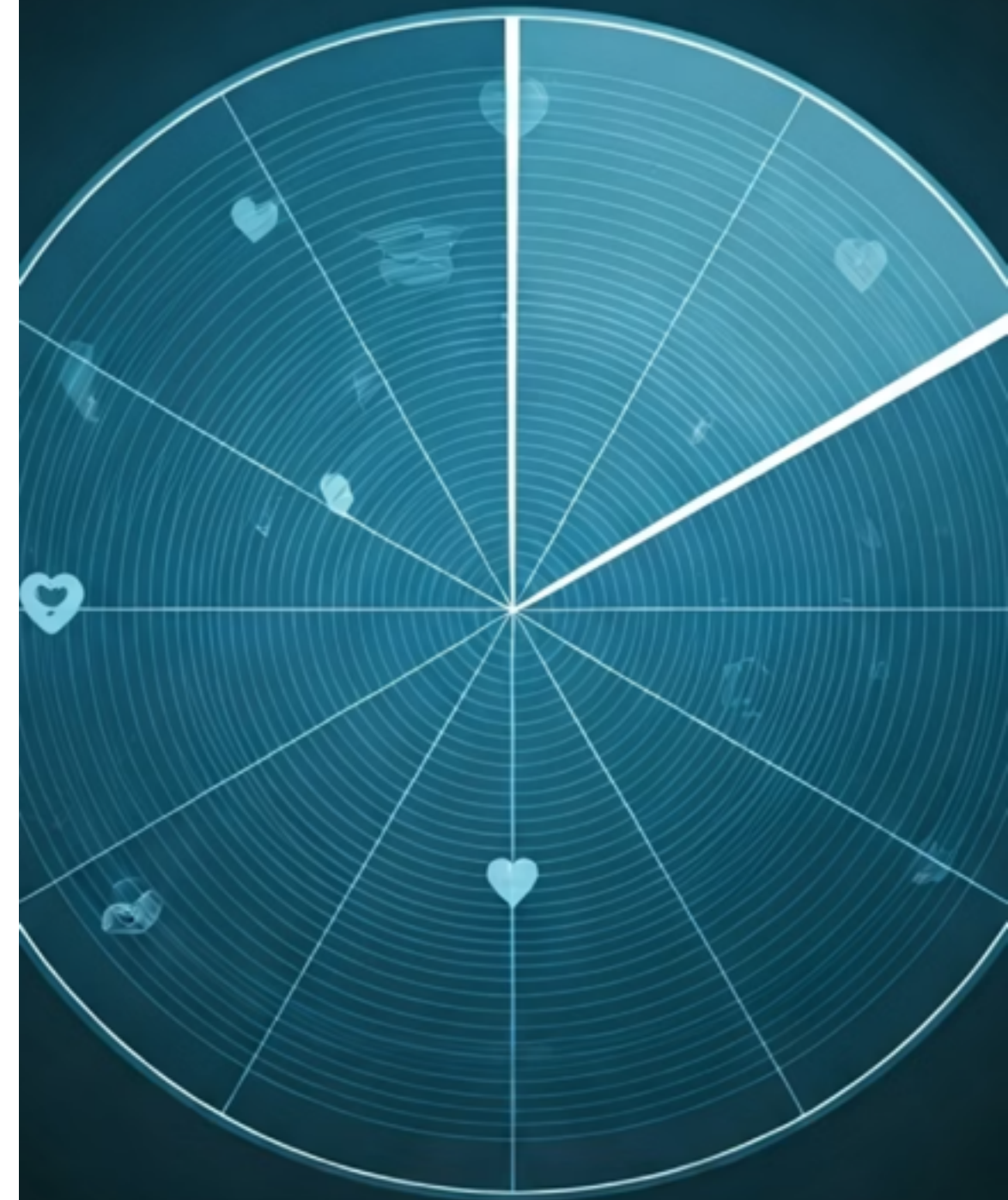
Job-Related Factors

- High risk job role
- Seniority in org chart
- Involvement in high risk project
- High risk data access rights



Behavioural Indicators

- Completion of specific training
- Threatening behaviour
- Negative sentiment



Technical Indicators & Risk Profiles

Abuse of Legitimate Privileges

- Off-hours logins - outside of their norm
- Access to systems or data outside of job scope
- Unexpected privilege escalation
- Use of personal devices (BYOD)

Data Exfiltration Techniques

- Increased file access rate
- Transfer to external storage
- Email or Upload files externally
- Large or multiple print jobs
- Physical removal of documents or equipment
- Hide data in allowed channels
- Personal cloud services

Exploiting Insufficient Security Controls

- Poor Segregation of Duties
- Lack of Monitoring/Logging
- Weak Authentication
- Unpatched Systems
- Excessive access privileges
- Disabling security tools
- Use of anonymizers internally
- Other attempts to bypass monitoring

Onboarding

New employees learning systems and boundaries

Life Changes

Personal circumstances affecting behaviour

1

2

3

4

Role Changes

Shifting responsibilities and access requirements

Departure

Most IP theft occurs 30-90 days from resignation announcement



Stories by the Dumpster Fire



Financial Gain: A Case Study

Windsor doctor fined 12.5k for viewing records of newborn baby boys, then offering to sell circumcision services to the parents in 2025.

He claimed to not know that he wasn't allowed to do this.



Compromised Staff

Coinbase Outsourced Rogue Staff

Leaked 69,000 customers data. Paid \$200/photo.

Data to be used to target and extort crypto account holders.

Desjardins Employee (2019)

Collected information about customers and shared it with a 3rd party.

Data included name, address, birth date, SIN, email, and transaction habits of 2.7m people and 173k businesses

Fraud Cases

Ex-AHS Employee (2023)

Fined 12k for falsifying 200 COVID vaccination records

Alberta Veterans Group (2025)

Calgary police charged a former volunteer secretary with fraud after 67K was funnelled to Scotia Developments, her husband's company

Amelia Baptist Church, Florida (2025)

Church financial secretary spent \$570K on her church credit card for personal expenses

NYC Pension Fraud (2025)

Employee sentenced for stealing 646k worth of pension cheques

Florida School Employees (2025)

Retirement accounts drained of \$1M

Unintentional Breaches

Data Stored in Vulnerable Transfer Tool

Stored for long periods of time in vulnerable transfer tool

- Ontario birth registry breached
- Microsoft Nuance breached - \$8.5m lawsuit

AHS Unencrypted Laptop (2013)

Stolen laptop containing 620,000 patient records of Medicentres Canada



Building your insider risk program

1

Executive support

2

Stakeholders

- Executives
- Legal
- HR
- Privacy
- IT
- Infosec
- Corporate security
- Risk & Compliance
- Finance
- Unions or Professional colleges
- Any team that handles data
- Corporate Communications

3

Program Ownership and Principles

- Who is the owner of the program?
- Guiding principles, policy, procedures
- Address legal obligations
- Identify critical assets to protect

4

Start small - find viable use case / audience

- Focus on data / IP theft first
- Fraud
- Sabotage, violence are harder to identify

5

Essential Metrics

- Data exposure events by severity
- Risk indicators by file/destination/user
- Percentage change in posture over time
- Awareness training completion rates
- Detection method effectiveness



Tie into existing programs



Policies

- Acceptable Use
- Workplace violence
- Whistleblower
- Ethics



Processes

- Culture aligned guidance
- Appropriate paths for data and data sharing
- What can you bring in, what can you take out
- Legal and regulatory obligations



Awareness training

- Code of conduct
- Corporate policies
- Impact on company
- Transparency



Employee engagement and recognition

- Work-life balance programs
- Employee morale events
- Team building exercises
- Vacations / mandatory leave
- EFAP
- 1:1's
- Upward feedback



HR Processes

- Onboarding and off-boarding
- What can you take with you when you leave
- Background checks
- Role change training reminders for data handling
- Progressive management or discipline
- RACI



Other Programs

- Fraud prevention
- Security incident response
- Incident aligned micro training

Program Implementation Steps

Advertise the program, why, get buy in

Build relationships and processes

Use existing toolsets first

- Audit logs
- Data labelling
- DLP
- EDR
- IAM
- SIEM
- PIM / PAM
- UBA / UEBA / UAM
- HRMS / HCM

Build, buy, and test toolsets

Start small, engage the target group

Deploy, report, iterate, feedback



Detection methods



IRM tools



Other data flow

Look for "Whoops! My bad"



External audit



External entity



DLP tools



Employee reporting



Outage or failure



Honey tokens

Monitor for Exact Data Match



Privacy controls and considerations

Privacy controls are key to employee engagement and program success:

- Multi-level approvals for conducting investigations
- Audit logging of investigator actions
- RBAC controls on which data is visible to whom
- Deletion of cases that did not proceed
- Anonymization of investigation data - reduces cognitive biases

UAM - be very careful with this.

- Keystroke capture
- Screenshots
- File content
- File shadowing
- Webcam capture
- Endpoint replay

May violate other privacy laws, certain to erode any form of employee engagement or trust



Incident Engagement

Approach

- Light touch
- These are also your people
- Might be accidental, learning opportunity
- Might be compromised and need help
- Might be malicious
- You will need their help to investigate

Alert Handling

- Low risk alerts - automate awareness/messaging
- Critical/high - review asap
- Medium - review weekly

Program Review

- Monthly - tune, enhance integrations, review tooling updates
- Quarterly - add new use cases



Evidence collection



Images



Logs



Interviews



Anomaly detection

Additional Recommendations

- Follow a model of reviewing events daily, tuning alerts and policies weekly, new variants monthly
- Targeted role based training as part of a compassionate insider risk program to change behaviours during response actions.
- Targeted or repeat monitoring is considered workplace harassment
- Process must include HR for identifying increased individual risk
- Differentiate between administrative or user audits (HR/manager request) vs insider threat investigation
- Standard Operating Procedures or policies with defined actions are key
- Don't forget to tabletop these scenarios
- Take your time and do it well



Closing

1

Do the basics first

This builds on everything else you've done

2

Start with your people

- Partnerships
- Communication
- Transparency
- Be empathetic

3

Get policies approved and in writing

4

Start small - iterate with purpose

5

Tools only serve as a possible set of indicators

If your org isn't ready for this.

That's okay.

Resources & Links

M365Maps - Enterprise Landscape

<https://m365maps.com/files/Microsoft-365-Enterprise-Landscape.htm>

Australian Government - Digital Transformation Authority - Protected Utility Blueprint

<https://blueprint.asd.gov.au>

<https://blueprint.asd.gov.au/configuration/purview/>

Verizon 2025 Data Breach Investigation Report

<https://www.verizon.com/business/resources/reports/dbir/>

2025 Ponemon Insider Threat Report

<https://ponemon.dtexsystems.com/>

IBM Cost of a Data Breach Report 2025

<https://www.ibm.com/reports/data-breach>

CISA Insider Threat Mitigation Guide

<https://www.cisa.gov/resources-tools/resources/insider-threat-mitigation-guide>

CCCS How to protect your organization from insider threats (ITSAP.10.003)

<https://www.cyber.gc.ca/en/guidance/how-protect-your-organization-insider-threats-itsap10003-0>

CCCS Critical Infrastructure Resilience to Insider Risk

<https://www.publicsafety.gc.ca/cnt/rsrcls/pblctns/nhncng-crtcl-nfrstrctr/nhncng-crtcl-nfrstrctr-en.pdf>

Microsoft Insider Risk Management

<https://learn.microsoft.com/en-us/purview/insider-risk-management-solution-overview>

Implementing Insider Risk Management

<https://learn.microsoft.com/en-us/training/paths/purview-implement-insider-risk-management/>

Microsoft Insider Risk Management Interactive Walkthrough

<https://mslearn.cloudguides.com/guides/Get%20started%20with%20Microsoft%20Purview%20Insider%20Risk%20Management>

Microsoft Building a Holistic Insider Risk Management Program

<http://aka.ms/insiderriskreport>

Revealing the Multi-Perspective Factors Behind Insider Threats in Cybersecurity

<https://jmiw.uitm.edu.my/images/Journal/Vol17No2/Revealing.pdf>

Understanding factors that influence unintentional insider threat - a framework to counteract unintentional risks

<https://pmc.ncbi.nlm.nih.gov/articles/PMC8550909/>

Resources & Links

National Insider Threat Task Force

<https://www.dni.gov/index.php/ncsc-how-we-work/ncsc-nittf>

Building an effective insider risk management program

<https://www.pwc.com/us/en/technology/alliances/microsoft/cybersecurity/insider-risk-management.html>

GIAC 957 - Espionage and the Insider

<https://www.giac.org/paper/gsec/957/espionage-insider/101921>

GIAC 3425 - The Unintentional Criminal - DDoS from the inside!

<https://www.sans.org/white-papers/1307>

GIAC 9284 - Protecting Against Insider Attacks

<https://www.sans.org/white-papers/33168>

GIAC 17794 - Mitigating Insider Sabotage

<https://www.giac.org/paper/gsec/17794/mitigating-insider-sabotage/118261>

GIAC 36307 - Insider Threat Mitigation Guidance

<https://www.giac.org/paper/gsec/957/espionage-insider/101921>

GIAC 37885 - Offensive Intrusion Analysis - Insiders with Threat Hunting and Active Defence

<https://www.giac.org/paper/gcih/20661/offensive-intrusion-analysis-uncovering-insiders-threat-hunting-active-defense/128770>

GIAC 39055 - Attackers Inside the Walls - Detecting Malicious Activity

<https://www.giac.org/paper/gcia/13352/attackers-walls-detecting-malicious-activity/165387>

GIAC 39975 - Continuous Monitoring Effectiveness Against Detecting Insider Threat

<https://www.sans.org/white-papers/39975>

GIAC 40190 - Insider Threat The Theft of Intellectual Property in Windows 10

<https://www.giac.org/paper/gcfe/1046/insider-threat-theft-intellectual-property-windows-10/133768>

The CERT Guide to Insider Threats [2012] - Dawn M. Capelli

The Big Picture of Insider IT Sabotage Across U.S. Critical Infrastructures [2009] - Dawn M. Capelli

Seven (Science-Based) Commandments for Understanding and Countering Insider Threats

https://www.nist.gov/system/files/documents/2023/04/03/2023-02-26%20Perserec_508_redacted.pdf

Insider Risk News Articles

Former SNC executive Wallace charged with bribery

https://www.yorkregion.com/news/former-snc-executive-wallace-charged-with-bribery/article_a8b5d2c1-baee-5964-a9e4-eb1309566d15.html

Developer gets 4 years for activating network “kill switch” to avenge his firing

<https://arstechnica.com/tech-policy/2025/08/developer-gets-4-years-for-activating-network-kill-switch-to-avenge-his-firing/>

Brazilian police arrest IT worker over \$100 million cyber theft

<https://therecord.media/brazil-police-arrest-worker-theft>

Ex-US soldier who Googled 'can hacking be treason' pleads guilty to extortion

https://www.theregister.com/2025/07/15/solider_hacking_guilty/

'Who let her in??!' Minister's staff accidentally text deliberations about 15 per cent spending cut to reporter

<https://nationalpost.com/news/politics/ministers-staff-accidentally-text-deliberations-about-15-per-cent-spending-cut-to-reporter>

Former WhatsApp security boss in lawsuit likens Meta's culture to a “cult”

<https://arstechnica.com/security/2025/09/former-whatsapp-security-boss-sues-meta-for-systemic-cybersecurity-failures/>

Ex-Meta employee files whistleblower suit for alleged security flaws at WhatsApp

<https://www.cnn.com/2025/09/08/ex-meta-employee-whistleblower-suit-alleged-security-flaws-whatsapp-.html>

397 Medical Records Snooped at Hamilton General Hospital

https://www.thespec.com/news/hamilton-region/397-medical-records-snooped-at-hamilton-general-hospital/article_83649841-47a5-58ca-9fde-f843f8992bfa.html

HHS fires 8 employees who 'snooped' through records of 4,000 patients

<https://www.cbc.ca/news/canada/hamilton/hhs-data-breach-1.6949786>

Data breach exposed health info on pregnancies and births of 3 million Ontarians

<https://nationalpost.com/news/canada/perinatal-child-registry-data-breach-affects-3-million-ontarians>

Microsoft's Nuance coughs up \$8.5M to rid itself of MOVEit breach suit

https://www.theregister.com/2025/08/18/nuance_lawsuit/

Calgary woman charged with embezzling \$67K from veterans' group

<https://www.cbc.ca/news/canada/calgary/embezzle-calgary-veterans-group-1.7455670>

Suspect in Coinbase hack kept data for more than 10,000 customers on her phone, court filing alleges

<https://fortune.com/crypto/2025/09/16/coinbase-hack-taskus-indore-india-ashita-mishra-coinbase-employees/>

Coinbase Faces Multiple Lawsuits Over Bribed Support Agents and User Data Leak

<https://cryptonews.com/news/coinbase-faces-multiple-lawsuits-over-bribed-support-agents-and-user-data-leak/>

Coinbase Agents Bribed, Data of ~1% Users Leaked; \$20M Extortion Attempt Fails

<https://thehackernews.com/2025/05/coinbase-agents-bribed-data-of-1-users.html>

Church secretary steals \$570,000, takes Grand Canyon helicopter tour, FL cops say

<https://www.miamiherald.com/news/state/florida/article303939191.html>

NYC employee sentenced for stealing \$646,000 worth of pension checks

<https://pix11.com/news/local-news/nyc-employee-sentenced-for-stealing-646000-worth-of-pension-checks/>

Insider Risk News Articles

Florida school employees' retirement accounts drained of \$1M in fraud scheme, feds say

<https://www.miamiherald.com/news/state/florida/article300899469.html>

Cisco's ex-employee gets 2 years in prison for accessing Webex Teams without authorization

<https://hr.economictimes.indiatimes.com/news/trends/indian-origin-man-gets-2-years-in-prison-for-webex-teams-hack/79751451>

Former Sysadmin Accused of Planting "Time Bomb" in Company's Database

<https://www.bleepingcomputer.com/news/security/former-sysadmin-accused-of-planting-time-bomb-in-companys-database/>

Ex-employee on toxic work environment at Canadian company: 'I cut my leg open to get a day off'

<https://www.moneycontrol.com/news/trends/ex-linus-tech-tips-employee-on-toxic-workplace-i-purposefully-cut-my-leg-open-to-get-a-day-off-11206381.html>

Cloud engineer gets 2 years for wiping ex-employer's code repos

<https://www.bleepingcomputer.com/news/security/cloud-engineer-gets-2-years-for-wiping-ex-employers-code-repos/>

Disgruntled ex-employee leaks Twitter source code

<https://www.hcamag.com/ca/specialization/employment-law/disgruntled-ex-employee-leaks-twitter-source-code/440819>

IT admin admits sabotaging ex-employer's network in bid for higher salary

<https://www.tripwire.com/state-of-security/it-admin-admits-sabotaging-ex-employers-network>

Admin from hell facing 10 years for sabotaging ex-employer's network

<https://www.malwarebytes.com/blog/news/2022/10/ex-employee-faces-10-years-in-prison-for-misusing-login-details>

Windsor, Ont., doctor fined after wrongfully accessing health records to offer circumcision services

<https://www.cbc.ca/news/canada/windsor/windsor-doctor-1.7621211>

Ontario bureaucrat accused of scamming \$11M now accused in alleged \$30M fraud

<https://www.cbc.ca/news/canada/toronto/ontario-employee-sanjay-madan-covid-fraud-1.5893805>

Church administrator embezzled \$400K, Winnipeg police say

<https://www.cbc.ca/news/canada/manitoba/church-administrator-embezzled-400k-winnipeg-police-say-1.3391808>

Toronto lawyer couple sentenced to jail for contempt over millions in missing homebuyer funds

<https://www.cbc.ca/news/canada/toronto/cartel-bui-lawyers-sentenced-contempt-1.7364329>

Former Lake Louise resort CFO sent to prison, fined total of \$775K after convictions for fraud, tax evasion

<https://www.cbc.ca/news/canada/calgary/lake-louise-cfo-derek-kwasney-fraud-tax-evasion-prison-fine-1.7383527>

3rd person charged in connection with alleged fraud at Calgary non-profit

<https://www.cbc.ca/news/canada/calgary/discover-bowness-bowcommons-calgary-police-1.7574442>

Lies and scandal: How two rogue scientists at a high-security lab triggered a national security calamity

<https://www.cbc.ca/news/politics/winnipeg-lab-firing-documents-released-china-1.7130284>

'Wake-up call for Canada': Security experts say case of 2 fired scientists could point to espionage

<https://www.cbc.ca/news/canada/manitoba/winnipeg-lab-security-experts-1.6059097>

Ex-ASML employee accused of data theft is being probed for ties to China

<https://www.scmp.com/tech/tech-war/article/3211584/ex-asml-employee-accused-data-theft-being-probed-ties-china>

Insider Risk News Articles

Insider Threat Articles galore:

<https://www.bleepingcomputer.com/tag/insider-threat/>

Former Alberta Health Services employee fined \$3,000 for breaching client files

<https://www.cbc.ca/news/canada/edmonton/ahs-client-health-record-breach-1.4076461>

Health records of 3,224 Red Deer hospital patients involved in privacy breach, health authority says

<https://www.cbc.ca/news/canada/edmonton/red-deer-hospital-patient-record-breach-ahs-1.5986734>

AHS investigating alleged privacy breach by 48 Calgary employees

<https://calgaryherald.com/news/local-news/ahs-investigating-privacy-breach-by-48-calgary-employees>

Former Alberta Health Services employee fined for unauthorized disclosure of health information

<https://oipc.ab.ca/former-alberta-health-services-employee-fined-for-unauthorized-disclosure-of-health-information/>

Former AHS worker inappropriately accessed 1,300 health records, viewed thousands more

<https://edmontonjournal.com/news/local-news/former-ahs-worker-inappropriately-accessed-1309-health-records-viewed-thousands-more>

Court case concludes in sentencing for offence under Health Information Act - falsifying COVID-19 immunization records

<https://oipc.ab.ca/court-case-concludes-in-sentencing-for-offence-under-health-information-act/>

<https://www.westernstandard.news/news/ex-ahs-employee-fined-12000-for-falsifying-200-covid-health-records/60666>

Desjardins Group (2019): A single employee leaked data on 9.7 million Canadians.

<https://www.cbc.ca/news/canada/montreal/desjardins-data-breach-explain-1.5185163>

Questions?

Thank you

Contact Info:

singleusermode@infosec.exchange
nixuser23@gmail.com

Do not contact me on LinkedIn unless
you talk to me first.

<https://github.com/nixy23/presentations>

